João Pedro da Silva Ribeiro

Parte 1 — Exercícios teóricos

Exercício 1 — Autenticação e autorização

Autenticação é o processo de verificar a identidade de um usuário, ou seja, confirmar se ele realmente é quem diz ser. Isso geralmente acontece por meio de um login e uma senha.

Autorização é o processo de verificar quais permissões esse usuário possui dentro do sistema, determinando quais ações ele pode realizar.

Exemplo de autenticação: Um usuário precisa informar seu e-mail e senha para conseguir acessar uma API de um sistema escolar.

Exemplo de autorização: Depois de realizar o login, um aluno pode consultar suas notas, mas somente um professor possui permissão para cadastrar ou alterar as notas dos alunos.

O JWT (JSON Web Token) é um padrão utilizado para transmitir informações de autenticação entre o cliente e o servidor.

O funcionamento acontece da seguinte maneira:

1. O usuário informa seu login e senha no sistema.
2. A API recebe os dados e verifica se estão corretos.
3. Se as informações forem válidas, o servidor gera um token JWT e envia para o cliente.
4. O cliente armazena o token e o utiliza nas próximas requisições.
5. Para acessar uma rota protegida, o cliente envia o token no cabeçalho HTTP da requisição.
6. A API verifica se o token é válido. Se estiver correto, permite o acesso à rota, respeitando também as permissões do usuário.

Qual é a finalidade do token JWT?

Sua finalidade é identificar o usuário e permitir que ele acesse rotas protegidas sem precisar informar seu login e senha em todas as requisições.

Como o cliente envia o token nas próximas requisições?

O cliente envia o token no cabeçalho HTTP chamado Authorization, utilizando o formato Bearer.

Para que serve o cabeçalho HTTP Authorization: Bearer?

Serve para informar à API que a requisição está sendo enviada com um token de autenticação, permitindo que o servidor verifique a identidade do usuário.

Por que não devemos colocar senhas ou informações secretas no conteúdo do token?

Porque o conteúdo de um JWT pode ser decodificado e visualizado por outras pessoas. Portanto, senhas e informações confidenciais não devem ser armazenadas nele, pois podem ser expostas.

Exercício 3 — Status HTTP 401 e 403

Os códigos HTTP 401 e 403 são utilizados para indicar problemas relacionados ao acesso a recursos de uma API, mas possuem significados diferentes.

HTTP 401 Unauthorized

Indica que o usuário não foi autenticado corretamente. Isso pode acontecer quando ele não envia um token, utiliza um token inválido ou apresenta um token expirado.

Exemplo prático: Um usuário tenta acessar uma rota protegida da API sem enviar o token JWT. O servidor retorna o código 401, pois não conseguiu autenticar o usuário.

HTTP 403 Forbidden

Indica que o usuário já foi autenticado, mas não possui autorização ou permissão para realizar determinada operação.

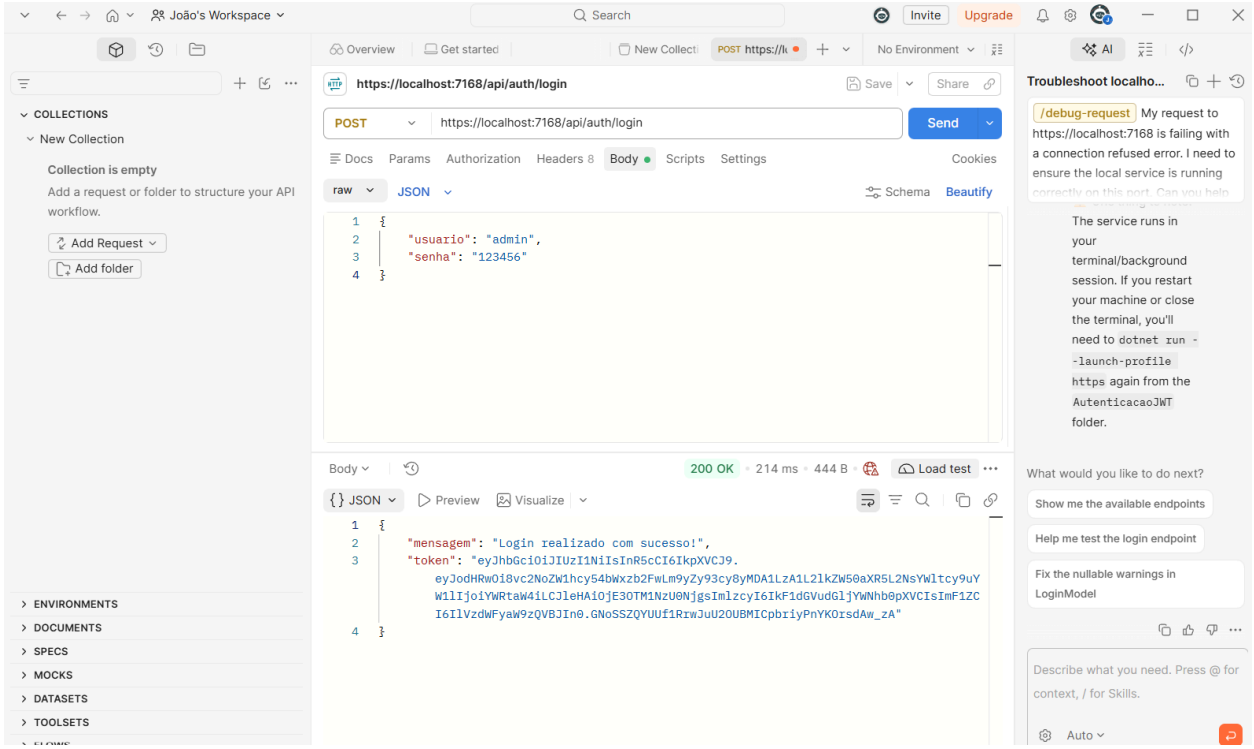
Exemplo prático: Um aluno realiza o login corretamente e recebe um token JWT, mas tenta acessar uma rota exclusiva para professores, como cadastrar notas. Como não possui essa permissão, a API retorna o código 403.

Principal diferença:

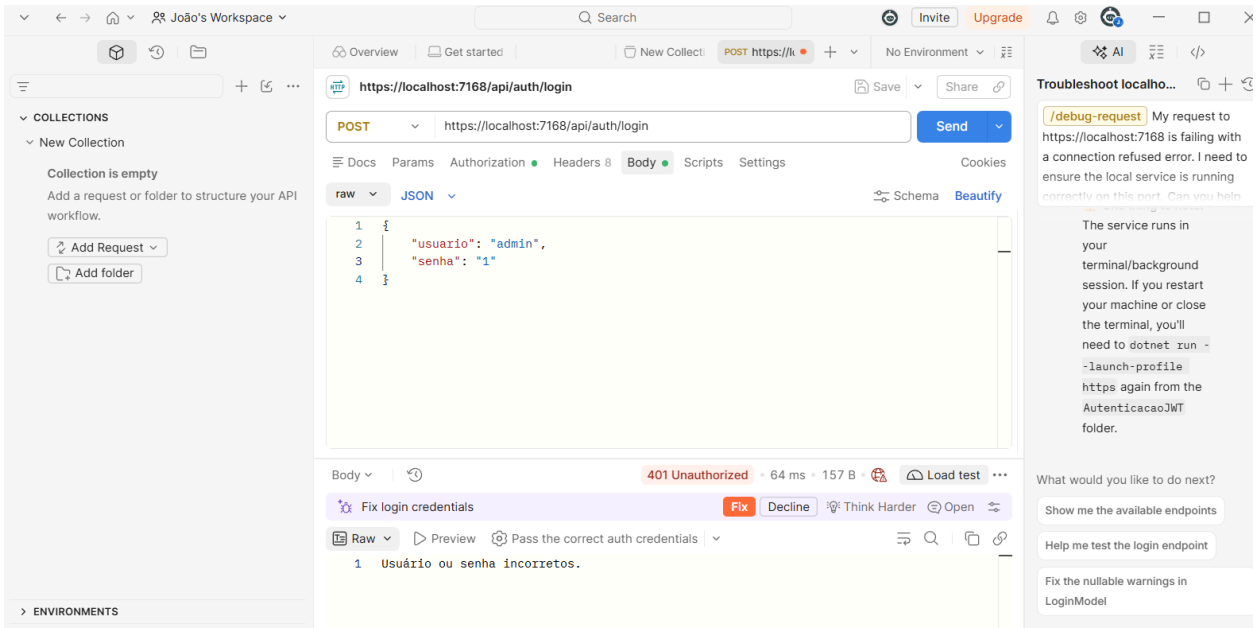
- 401: O usuário não foi autenticado corretamente.
- 403: O usuário foi autenticado, mas não tem permissão para acessar determinado recurso.

Parte 2 Prints dos testes

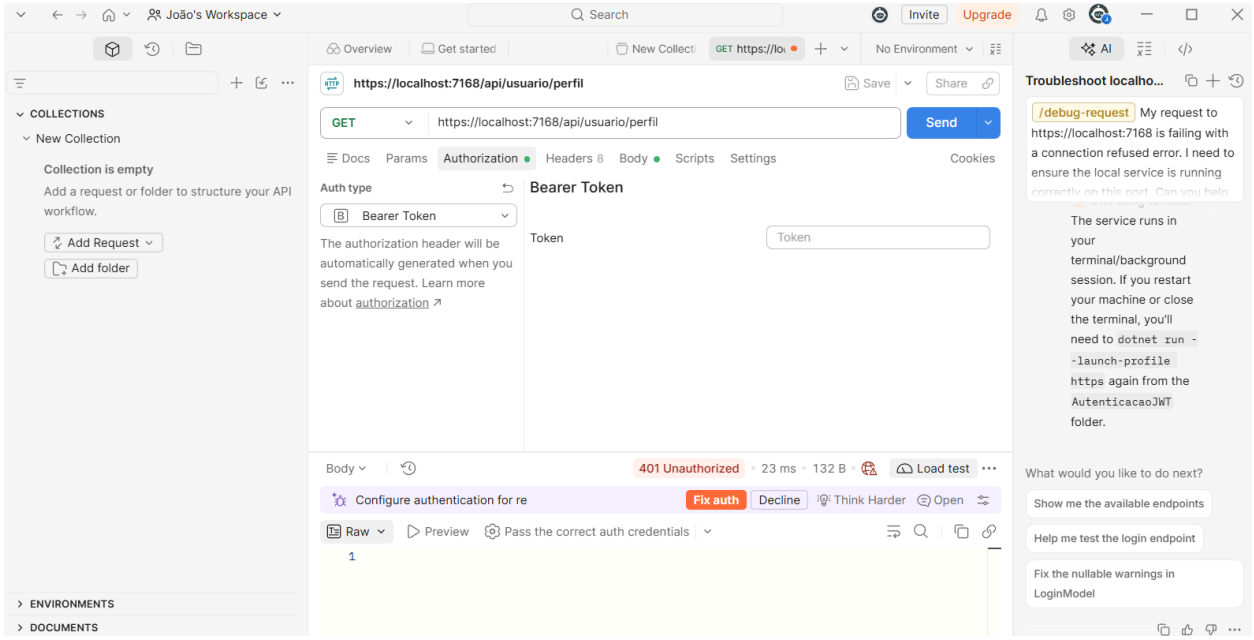
Usuario e senha corretos:



Usuario ou senha incorretos



Acesso sem o token



Acesso com o token

